

PRINCIPAL ENTERPRISE ARCHITECT REFERENCE SERIES

VOLUME 5 OF 8

Enterprise Review Questions & Scorecards

A structured question bank across seventeen review domains, plus the scorecards that turn review answers into consistent, auditable approval decisions.

Enterprise Architecture Review Board Handbook · Banking & Financial Services Edition

Part A — Review Question Bank, Domains 1-9

This question bank is organized by domain rather than presented as one undifferentiated list, because the right questions to ask depend heavily on what's actually being reviewed. For each domain, a representative core set of questions is developed in full (why it's asked, what a good answer looks like, red flags, and natural follow-ups), followed by an extended rapid-reference list covering the breadth a Principal Architect should have at hand. Across both parts of this volume, the question bank spans seventeen domains and several hundred individual questions.

HOW TO USE THIS BANK IN AN ACTUAL REVIEW

No single review should attempt all questions in a domain — that produces review fatigue and superficial answers. Select 5-10 questions per relevant domain based on the specific risk profile of what's being reviewed. The "why asked" framing for each core question is designed to help you select intelligently rather than mechanically working through a checklist.

9.1 Business Domain

Q: WHAT BUSINESS CAPABILITY DOES THIS INITIATIVE SERVE, AND IS THERE AN EXISTING SYSTEM ALREADY SERVING IT?

Why asked: Surfaces capability redundancy (see Volume 3, Section 6.3) before investment is committed, not after.

Expected answer: A specific capability map reference, with explicit acknowledgment of any overlapping existing systems and rationale for why a new build is still warranted.

Red flags: "We didn't check" or a capability map reference that doesn't actually exist; vague capability naming that could mean almost anything.

Follow-up: If overlap exists, why wasn't the existing system extended instead of building new?

Q: WHAT IS THE QUANTIFIED COST OF DELAY IF THIS IS NOT APPROVED THIS CYCLE?

Why asked: Forces economic rigor (Volume 2, Section 3.3) into the prioritization conversation rather than relying on urgency claims.

Expected answer: A CD3-style calculation or equivalent, ideally with the underlying assumptions visible.

Red flags: "It's urgent" with no supporting calculation; cost of delay that conveniently equals exactly the requested budget.

Follow-up: What specifically changes if this is delayed one quarter versus approved now?

Extended Business Domain Questions

- Who is the accountable business sponsor, and have they personally reviewed this submission?
- What is the expected business value, and how will it be measured post-implementation (tying to benefits realization, Volume 2 Section 3.10)?
- Does this initiative duplicate or conflict with another in-flight initiative elsewhere in the portfolio?
- What is the minimum viable scope that would still deliver meaningful business value?
- Has the business case been validated against actual customer/user research, or is it assumption-driven?
- What happens to current manual processes or workarounds this is meant to replace?
- Is this initiative driven by competitive pressure, regulatory requirement, internal efficiency, or a combination — and how does that affect the acceptable risk/timeline trade-off?
- Who are the downstream business consumers of this capability, and have they been consulted?
- What is the expected customer-facing impact, if any, and has it been validated with affected business units?
- Is there a simpler, lower-risk way to achieve the same business outcome?
- What is the business continuity impact if this system experiences an extended outage?
- Does this initiative align with the current three-year technology strategy, or does it represent a deviation that needs explicit justification?

9.2 Architecture Domain

Q: WHAT ARCHITECTURAL PATTERN DOES THIS FOLLOW, AND WHY WAS IT CHOSEN OVER ALTERNATIVES?

Why asked: Tests whether the design is deliberate (informed by the pattern catalog, Volume 3 Section 5.5) or accidental.

Expected answer: A named pattern with explicit reference to the trade-off analysis (ATAM-style, Volume 2 Section 4.6) that led to its selection.

Red flags: "This is just how we always build things" with no comparison to alternatives; a pattern name used incorrectly, suggesting cargo-cult application without real understanding.

Follow-up: What quality attributes did this pattern choice sacrifice, and was that trade-off consciously accepted?

Extended Architecture Domain Questions

- What are the system's bounded context boundaries, and do they align with the enterprise domain model?
- What existing reference architecture, if any, does this conform to — and if it deviates, why?
- What is the blast radius if a core component fails?
- How does this architecture handle backward and forward compatibility for its interfaces?
- What architectural debt is this introducing, even if justified, and has it been logged?
- Is the architecture coupled to a specific vendor or technology in a way that constrains future flexibility?
- What is the data consistency model (strong, eventual, etc.) and is it appropriate for the use case?
- How many systems does this integrate with, and is that integration complexity proportionate to the value delivered?
- What is the architecture's approach to idempotency for critical operations (especially payments-adjacent flows)?
- Has this architecture been reviewed against the current enterprise reference architecture for this domain?
- What assumptions does this architecture make about scale, and at what point do those assumptions break?
- Is there a simpler architecture that would meet the same quality attribute requirements?

9.3 Security Domain

Q: WALK THROUGH THE AUTHENTICATION AND AUTHORIZATION MODEL END TO END.

Why asked: Authentication/authorization gaps are among the most common and most severe architecture review findings; a verbal walkthrough surfaces gaps a document review alone often misses.

Expected answer: A clear description of identity provider integration, token handling, and authorization enforcement points, ideally referencing zero-trust principles where applicable.

Red flags: Authorization logic embedded inconsistently across multiple services rather than centrally enforced; reliance on network-perimeter security as the sole control; inability to clearly describe how a specific unauthorized access attempt would be blocked.

Follow-up: How is this tested — is there an automated test suite specifically for authorization boundary cases, including negative tests?

Extended Security Domain Questions

- What is the data classification of information processed by this system, and does the architecture match the required control level?
- How is encryption key management handled, and who has access to keys?
- What is the threat model, and has it been reviewed by the Security Council (Volume 1, Section 1.1)?
- What third-party/vendor components are in the security-critical path, and what is their security posture?
- How are secrets (API keys, credentials) managed — is there any hardcoding or insecure storage risk?
- What is the logging and monitoring coverage for security-relevant events, and is it tamper-evident?
- How does this architecture handle a credential compromise scenario — what's the blast radius and recovery process?
- Has this architecture undergone penetration testing or is it scheduled to?
- What is the data residency and cross-border data transfer posture, and does it comply with applicable regulations?
- Does this introduce any new attack surface (new public endpoints, new third-party integrations)?
- How are AI/agent tool permissions scoped — could an AI component take an action beyond its intended authority?
- What is the incident response plan specific to this system, and has it been tested?

9.4 Cloud Domain

Extended Cloud Domain Questions

- Which cloud regions/availability zones does this deploy to, and does that satisfy resilience and data residency requirements?
- Has this been reviewed by the Cloud Center of Excellence against current landing zone standards?
- What is the auto-scaling configuration, and has it been load-tested against realistic peak scenarios?
- Is this architecture portable across cloud providers, or is it deeply coupled to provider-specific services — and is that an acceptable trade-off?
- What is the disaster recovery architecture, and what are the tested RTO/RPO figures (not just targets)?
- How are cloud costs projected to scale with usage growth, and has FinOps reviewed the projection?
- What native cloud security services are leveraged (e.g., managed key services, network security groups) versus custom-built equivalents?
- Is there a single point of failure introduced by reliance on a specific cloud service tier or region?
- What is the egress cost model, and has it been factored into the cost projection?

- How does this architecture handle a full regional cloud outage?

9.5 Data Domain

Extended Data Domain Questions

- Who is the data owner, and has the Data Governance Council reviewed the data classification?
- What is the data lineage from source to consumption, and is it documented/traceable?
- What is the data retention policy, and is deletion (including from backups and downstream copies) actually achievable?
- Does this introduce a new copy of an existing golden-source data set, and if so, why wasn't the golden source consumed directly?
- What is the data quality validation approach, and what happens when bad data is detected?
- How is personally identifiable information (PII) handled — masking, tokenization, encryption — at each stage of the data flow?
- What is the master data management approach for entities this system creates or modifies?
- Is this data exposed as a reusable data product, or is it siloed to this system alone?
- What are the data consistency guarantees across the distributed components of this architecture?
- How does this architecture support data subject access/deletion requests under applicable privacy regulation?

9.6 AI Domain

Extended AI Domain Questions

- What specific model(s) are used, and what is the rationale for the choice versus alternatives (including cost, per Volume 2 Section 3.5)?
- What is the fallback behavior when the AI component is unavailable or produces low-confidence output?
- Has this use case been reviewed by the AI Governance Board, Responsible AI Council, and/or Model Risk Committee as appropriate (Volume 1, Section 1.2)?
- What is the explainability approach for decisions that affect customers (Volume 4, Section 8.2)?
- How is model drift monitored and what triggers retraining or human review?
- What data was the model trained or fine-tuned on, and does it raise any data governance or fairness concerns?
- What is the human-in-the-loop design — at what point, if any, does a human review or can override AI output?
- How is hallucination risk specifically mitigated for this use case?
- What is the cost-per-interaction at projected scale, and has it been modeled (token economics, Volume 2 Section 3.5)?
- Is there a prompt injection or adversarial input risk, and how is it mitigated?

9.7 Platform Domain

Extended Platform Domain Questions

- Does this use existing platform golden paths, or does it require platform team support for a novel pattern?
- What platform SLAs is this architecture dependent on, and are they sufficient for this use case's requirements?
- Is this introducing a new shared platform capability, and if so, has reuse potential been assessed across other teams?
- What is the deployment pipeline, and does it conform to platform engineering standards?
- How does this architecture handle platform-level maintenance windows or upgrades?

9.8 Operations Domain

Extended Operations Domain Questions

- Is there a completed Support Model artifact (Volume 4, Section 7.6), and has the operations team accepted it?
- What is the on-call escalation path, and does the supporting team have the necessary skills/access?
- What runbooks exist for known failure scenarios, and have they been tested (not just written)?
- What is the expected operational toil, and has it been weighed against the value delivered?
- How is capacity monitored, and what are the alerting thresholds for proactive intervention before customer impact?

9.9 Compliance Domain

Extended Compliance Domain Questions

- What specific regulations apply to this initiative, and is there a completed Compliance Matrix (Volume 4, Section 7.3)?
- Has Legal/Compliance formally reviewed and signed off, or is this an architect's interpretation of compliance requirements?
- What audit evidence will this architecture produce, and is it sufficient for a regulatory examination?
- Does this initiative cross jurisdictional boundaries, and if so, which jurisdiction's requirements govern?
- What is the change control process for compliance-relevant configuration, and is it auditable?

Part B — Review Question Bank, Domains 10-17, & Scorecards

9.10 FinOps Domain

- What is the projected monthly run cost at current scale, and at 3x and 10x scale?
- Has the architecture been reviewed against committed/reserved capacity options versus on-demand pricing?
- Who owns the cost center this will be charged to, and have they acknowledged the projected spend?
- What cost-monitoring alerts are configured to catch unexpected spend before it becomes material?
- Is there idle or underutilized capacity in the design that could be right-sized?

9.11 Vendor Domain

- What is the vendor's financial stability and long-term viability assessment?
- What is the contractual exit/migration path if the vendor relationship ends?
- Does this vendor meet the bank's third-party risk management requirements, including any critical-vendor regulatory regime?
- What data does the vendor have access to, and is that access proportionate and contractually bounded?
- Is there meaningful vendor lock-in, and has that been weighed against the value delivered?

9.12 Agent Domain

- Is there a completed Agent Specification (Volume 4, Section 7.5) defining scope of autonomy and tool access?
- What actions can this agent take without human approval, and is that scope proportionate to the risk of an error?
- How does the agent handle a task it cannot complete — does it fail gracefully and escalate, or risk fabricating success?
- What is the audit trail for actions taken autonomously by this agent?
- How is the agent's behavior tested against adversarial or edge-case inputs before production deployment?

9.13 Memory Domain

- What does this AI system remember across interactions, and is there a documented Memory Policy (Volume 4, Section 7.5)?
- How long is memory retained, and does that comply with data retention and privacy requirements?
- Can a user or data subject request their stored memory be reviewed or deleted, and is that technically achievable?
- What happens if memory becomes stale or contradicts current reality (context freshness, Volume 4 Section 8.2)?
- Is memory scoped per-user/per-session appropriately, with no risk of cross-contamination between users?

9.14 MCP Domain

- What tools are exposed via MCP (or equivalent) to AI agents, and is there a completed MCP Tool Contract (Volume 4, Section 7.5) for each?
- What is the permission scope of each exposed tool, and is it the minimum necessary for the agent's function?
- How is the MCP server itself secured against unauthorized access or tool misuse?
- Is tool output validated before being acted upon, or trusted implicitly?
- What happens if a tool call fails or returns unexpected output — is there safe failure handling?

9.15 A2A (Agent-to-Agent) Domain

- Is there a completed A2A Contract (Volume 4, Section 7.5) defining the trust boundary between agents?
- What prevents a compromised or malfunctioning agent from propagating bad actions to other agents it communicates with?
- Is there a circuit breaker or rate limit on agent-to-agent interactions to prevent runaway feedback loops?
- How is agent-to-agent communication authenticated and authorized?
- What is the human visibility into agent-to-agent interactions — can an operator observe and intervene in real time?

9.16 Networking Domain

- What network segmentation is applied, and does it follow zero-trust principles where applicable?
- What is the latency budget across the network path, and has it been measured, not just estimated?
- How is network traffic encrypted in transit, including internal east-west traffic, not just external-facing endpoints?

- What is the architecture's resilience to a network partition between components?
- Are there any unnecessary network exposure points (open ports, public endpoints) that could be tightened?

| 9.17 Identity Domain

- What identity provider is used, and is it the enterprise-standard one or a new/parallel identity store?
- How are service-to-service identities managed (e.g., workload identity, mutual TLS, service accounts)?
- What is the process for de-provisioning access when an employee or service is decommissioned?
- Is privileged access separately controlled and monitored versus standard access?
- How does this architecture handle identity federation if it spans organizational or partner boundaries?

| 9.18 Runtime Domain

- What is the runtime environment's patch and vulnerability management process?
 - How does the architecture handle a runtime dependency reaching end-of-life or end-of-support?
 - What is the container/runtime image provenance and verification process (supply chain security)?
 - What resource limits are configured to prevent a single component from degrading the broader runtime environment?
 - How is runtime configuration drift detected and corrected?
-

Part B (cont.) — Architecture Scorecards

Scorecards convert review answers into consistent, auditable approval decisions. The eleven scorecards below give the structural pattern; actual metric thresholds should be calibrated to your institution's specific risk appetite and regulatory environment rather than adopted verbatim. Full editable scorecard templates are provided in Volume 8.

10.1 Scorecard Structure (applies to all scorecards below)

Component	Purpose
Metrics	The specific, measurable indicators evaluated
Thresholds	Pass/conditional-pass/fail boundaries for each metric, calibrated to risk appetite
Weighting	Relative importance of each metric in the overall score — should mirror the weighted scoring discipline from Volume 2, Section 4.3, including pre-set weights to avoid reverse-engineered outcomes
Approval criteria	The composite score (or specific metric floor) required for unconditional approval, conditional approval, or rejection
Automation	Which metrics can be automatically sourced from monitoring/tooling versus requiring manual assessment

10.2 Business Scorecard

Metric	Weight	Pass Threshold	Automation
Quantified business value (NPV or equivalent)	30%	Positive NPV over defined horizon	Manual — finance-validated
Capability redundancy check completed	20%	No unaddressed redundancy, or explicit consolidation rationale	Semi-automated via knowledge graph
Sponsor accountability confirmed	15%	Named, engaged business sponsor	Manual
Benefits realization plan exists	20%	Defined, measurable post-implementation tracking plan	Manual
Strategic alignment	15%	Explicit mapping to current technology strategy	Manual

10.3 Architecture Scorecard

Metric	Weight	Pass Threshold	Automation
Reference architecture conformance	25%	Conforms, or documented/approved exception	Automated fitness function where available
Quality attribute coverage (Volume 4, Part B)	30%	All material attributes explicitly addressed with trade-offs documented	Manual
ADR completeness for significant decisions	20%	All major decisions documented	Manual review, automated completeness check
Technical debt introduced	15%	Quantified and explicitly accepted, or below threshold	Semi-automated
Pattern catalog alignment	10%	Uses established patterns or justifies novel approach	Manual

10.4 Security Scorecard

Metric	Weight	Pass Threshold	Automation
Threat model completed and reviewed	25%	Reviewed by Security Council, no unmitigated critical findings	Manual
Vulnerability scan results	20%	No unmitigated critical/high vulnerabilities	Fully automated
Authentication/authorization model reviewed	25%	Centrally enforced, tested with negative cases	Manual review, automated testing
Encryption coverage (at rest, in transit)	15%	100% for classified data	Automated
Penetration test status	15%	Completed or scheduled with acceptable interim controls	Manual

10.5 AI / Responsible AI Scorecard

Metric	Weight	Pass Threshold	Automation
Fairness testing completed	20%	Within defined parity thresholds across relevant groups	Semi-automated
Explainability requirement met	20%	Proportionate to decision stakes; regulatory minimum where applicable	Manual
Human-in-the-loop design appropriate to risk	20%	Defined escalation/override mechanism for high-stakes decisions	Manual
Model risk validation (where applicable)	20%	Model Risk Committee sign-off obtained	Manual gate
Cost-at-scale modeled	10%	Token/compute economics projected and accepted	Semi-automated
Drift monitoring configured	10%	Defined triggers for review/retraining	Automated once configured

10.6 Remaining Scorecards (Summary)

Scorecard	Top-Weighted Metrics
Cloud	Landing zone conformance; multi-AZ/region resilience; cost-at-scale; portability/lock-in assessment
Platform	Golden path usage; platform SLA dependency appropriateness; reuse potential of new platform capability
Operations	Support model completeness; runbook coverage and test status; on-call readiness
Developer Experience	Time-to-first-deployment for new contributors; documentation currency; golden path adherence
Data	Classification and lineage completeness; retention/deletion achievability; data product reusability
FinOps	Cost-at-scale accuracy; idle resource elimination; cost monitoring/alerting configured

A SCORECARD DISCIPLINE WORTH STATING EXPLICITLY

A composite passing score should never override a hard-fail on a single non-negotiable metric (e.g., an unmitigated critical security vulnerability). Mature scorecard designs distinguish weighted/compensatory metrics from gate metrics that cannot be averaged away — conflating the two is one of the more dangerous scorecard design mistakes, since it can produce an "approved" architecture that no individual reviewer would have actually approved on the merits.